

Task 1 : Introduction



EDR
Secure Every
Endpoint

✱ Endpoint Detection and Response (EDR) is a security solution designed to **monitor**, **detect**, and **respond** to **advanced threats** at the **endpoint level**. As a **SOC analyst**, it is essential for you to understand how the EDR works since it is a widely adopted solution in organizations to protect their endpoints.

EDR at a Glance



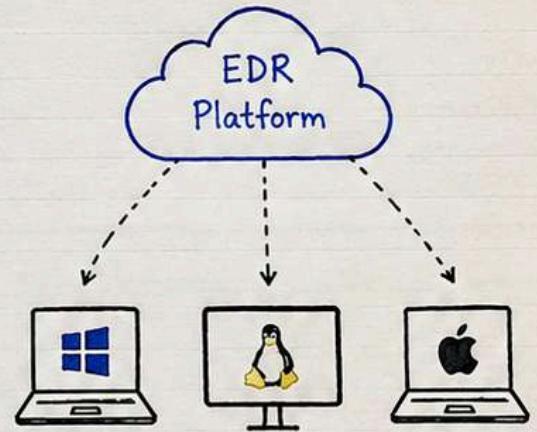
- ✓ Monitor
- ✓ Detect
- ✓ Respond
- ✓ Protect

→ In this room, we will see how an EDR differs from a traditional antivirus and what data it collects from the endpoints. We will also discuss the detection and response capabilities it provides.



Learning Objectives

- 1 Understand the basics of **EDR** and how it works
- 2 Differentiate **EDR** from traditional Antivirus solutions
- 3 Examine the architecture of an **EDR** solution
- 4 Analyze the types of telemetry it collects from endpoints
- 5 Understand the detection and response capabilities of an **EDR**
- 6 Investigate a realistic alert in the **EDR**



Protecting Every Endpoint



Room Prerequisites

- Basic knowledge of different endpoints (Windows, Linux, Mac) and the common attacks on them
- Awareness of the role of the **SOC** team



SOC Team



Remember: EDR goes beyond traditional antivirus by providing **visibility**, **detection**, and **response** across the entire attack lifecycle.

Task 2 : What is an EDR?

The increase in the use of digital devices is undeniable. Most of the business's core functions rely on these devices. Cyber threats are also increasing day by day. Organizations protect their network, but with **Remote Work**, endpoints are often outside the network perimeter.

→ **Endpoint Detection and Response (EDR)** is a security solution that provides deep-level protection for endpoints, no matter where they are. EDR constantly monitors endpoints and detects threats.

Some EDR solutions in the market:

- CrowdStrike Falcon
- SentinelOne ActiveEDR
- Microsoft Defender for Endpoint
- OpenEDR
- Symantec EDR
- And many more...



EDR

Protecting Endpoints,
Anywhere, Everywhere

EDR in Short

- ✓ Monitor
- ✓ Detect
- ✓ Respond
- ✓ Protect



Underlying architecture is mostly similar, but features may vary.

Let's look at the core features of an EDR. There are three main features, also known as the **three pillars** of an EDR solution.

Note: Screenshots are from CrowdStrike Falcon EDR.

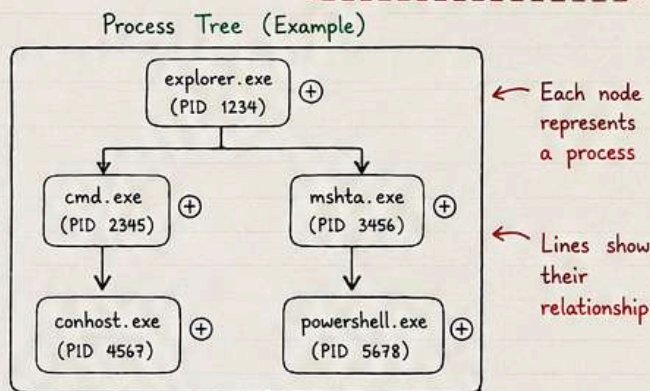
1 VISIBILITY

A good analysis depends on visibility. EDR provides an impressive level of visibility by collecting detailed data from endpoints. This includes process modifications, registry modifications, file and folder modifications, user actions, and much more. It presents this information in a structured format.

What can be seen for each process?

				...
Process Modifications	Registry Modifications	File & Folder Modifications	User Actions	And Much More

→ Analysts can view the whole process tree, activity timeline, access **historical data** for threat hunting, and more.



2 DETECTION

EDR uses both **signature-based** and **behavior-based** detections (e.g., unusual user activities). With **ML** capabilities, it detects **deviations from baseline** behavior and flags them instantly. It can detect fileless malware in memory and allows us to ingest **custom IOCs** for detections.

Detections Dashboard (Example)

Severity	Time	Triggering File	Hostname	Username	Tactic via Technique
High	2024-02-20 10:15:21	malicious.exe	WS-01	jdoe	Execution via PowerShell
Medium	2024-02-20 10:12:10	script.ps1	LAPTOP-10	asmith	Defense Evasion
Low	2024-02-20 10:10:05	rundll32.exe	SRV-02	svc_admin	Credential Access
High	2024-02-20 10:05:44	evil.docm	WS-07	jdoe	Initial Access
Medium	2024-02-20 10:02:18	wscript.exe	LAPTOP-22	mgreen	Execution

Clicking any detection shows rich details mapped to **MITRE**, helping **SOC** analysts during investigation.

3 RESPONSE

EDR empowers analysts to take action from a central console. You can isolate endpoints, **terminate** processes, **quarantine** files, **connect remotely**, and **execute actions** directly.

Host Actions (Example)

	Isolate Host
	Kill Process
	Quarantine File
	Connect to Host (Remote Shell)
	Run Script / Command
	Collect Forensics (Memory, Files, Logs)
	Unisolate Host

These actions can be performed on the endpoint from the EDR console.

★ Many other actions are available during an investigation.



With advanced visibility, detection, and response, EDR becomes a very powerful tool. However, remember: EDR is a **host-only** security solution and does **NOT** detect **network-level** threats.



Task 3 : Beyond the Antivirus

Before we proceed to the **HOW** behind the **EDR**'s working, let's answer a very common question that comes to mind when we hear about the **EDR** solution.



EDR

See More.
Detect More.
Respond Better.

Why do we need an **EDR** when we already have an **Antivirus (AV)** on the endpoints?

Both of these security solutions have the same motive of protecting the endpoint on which they are installed. However, both differ in the level of protection they provide.

The Airport Analogy

Antivirus (AV) = Immigration Check

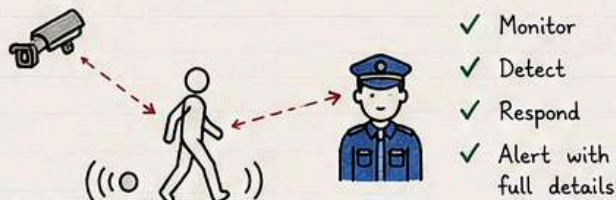
Monitors incoming people and matches their passports with a list of known criminals in its database.



If someone new (never seen before) and looks innocent comes in, AV will let them in. What if that person is a professional thief? An undetected threat is now inside!

EDR = Security Officers Inside the Airport

Constantly monitor CCTV cameras and motion sensors to identify suspicious behavior.



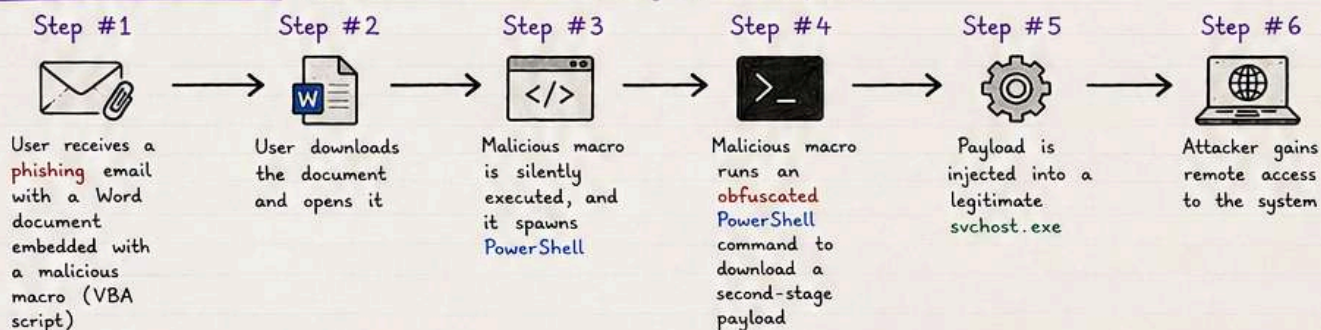
Security officers (EDR) will:

- Are they roaming close to restricted areas?
- Is their behaviour suspicious?
- Are they leaving their bags somewhere unattended?

If something doesn't feel right, officers can take action or alert airport management with full details.

The Antivirus (AV) may detect some basic threats, but to detect advanced threats that evade normal detections, we need an **EDR**. Unlike antivirus software's basic signature-based detection, it monitors and records the behaviors of the endpoint. An **EDR** also provides organization-wide visibility of any activity. For example, if a suspicious file is detected on one endpoint, the **EDR** will also check it across all the other endpoints.

Scenario Breakdown (Advanced Malicious Activity on an Endpoint)



Attack Steps	AV's Response	EDR's Response
Step #1	Does nothing if the downloaded file has no previous signature in the database	Logs the file download activity and monitors it
Step #2	Does nothing upon the opening of the document since winword.exe is a legitimate utility	Records the execution of winword.exe and keeps monitoring
Step #3	Does nothing if the executed macro has no previous signature	Detects and flags the macro execution due to the unusual parent-child relationship of winword.exe and PowerShell.exe processes
Step #4	Typically, AVs will not detect obfuscated PowerShell scripts	Flags the obfuscated script execution
Step #5	Will not flag malicious injection into svchost.exe since it does not monitor the memory injections	Detects Process Injection in svchost.exe
Step #6	Lacks Network Level Visibility	Flags the unexpected behaviour of svchost.exe, making an outbound connection
Final Action	May be marked as clean	Generates an alert with the full attack chain and enables the analyst to take actions from within the EDR

★ Note: Some modern AVs may have more enhanced visibility and detection. However, an **EDR** is ahead as it levels up the detection and response in an endpoint.



Think Beyond Signatures.
Detect Behaviors.
Respond Smarter.

Task 4 : How an EDR works?



EDR

See Everything.
Detect Anything.
Respond Instantly.

In the previous tasks, we saw how powerful an EDR is for an endpoint. However, do you know:

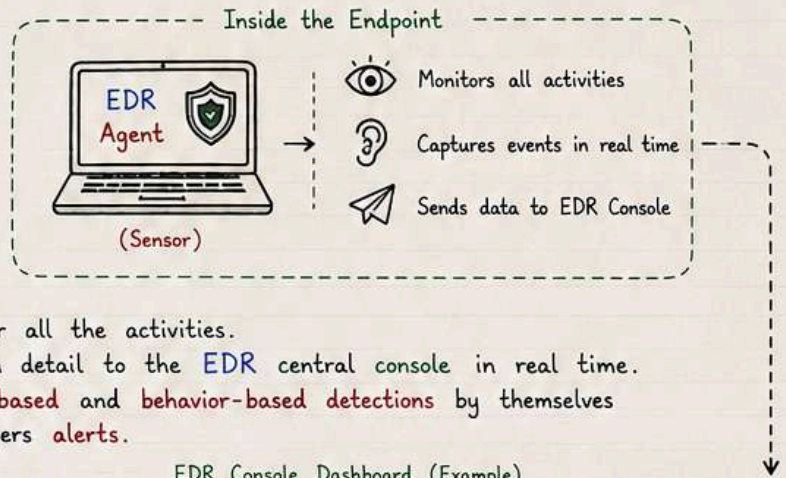
- How does an EDR manage to provide this much visibility of the endpoints?
- How can it detect advanced threats?
- How can a few clicks eradicate the threat from an endpoint?

This seems like magic. ✨ Let's try to understand it in a very simple way. ✨

1 AGENTS

We can integrate multiple endpoints with our EDR and manage them through a centralized console. There are EDR agents that we have to deploy inside those endpoints. These agents are also sometimes referred to as sensors. They are the eyes and ears of the EDR.

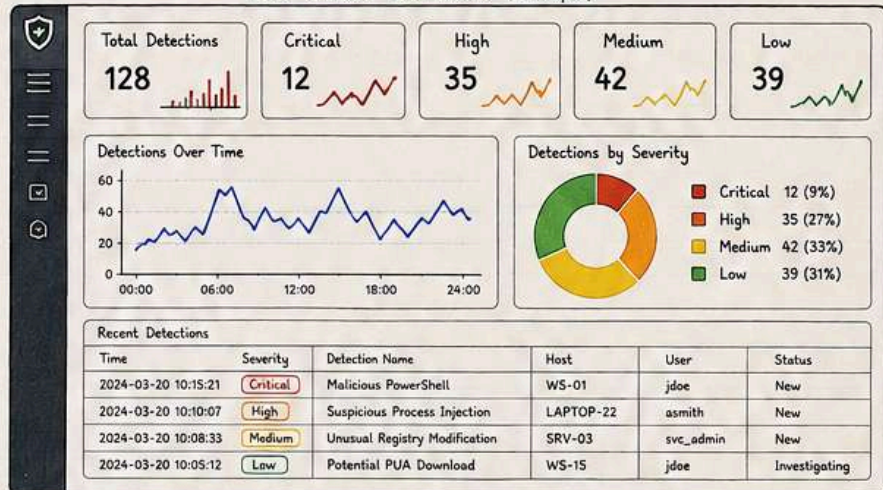
Their job is to sit at the endpoint and monitor all the activities. The information about these activities is sent in detail to the EDR central console in real time. The EDR agents can do some basic signature-based and behavior-based detections by themselves and send them to the EDR console, which triggers alerts.



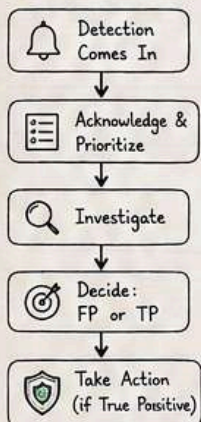
2 EDR CONSOLE

All the detailed data sent by the EDR agents is correlated and analyzed through complex logic and machine learning algorithms. The threat intelligence information is matched with the collected data. The EDR is just like the brain connecting all the dots. These dots connect to form a detection, often called an alert.

EDR Console Dashboard (Example)



3 WHAT HAPPENS AFTER DETECTION?



When a detection comes, it's a SOC analyst's responsibility to acknowledge the alert and prioritize it. The prioritization is made easy by the EDR itself. It gives severities to all the alerts (Critical, High, Medium, Low, Informational). The alert with the highest severity is investigated as a priority.

Once the alert is clicked, the analyst can see all the details of the detection. This includes any files executed, processes executed, network connection attempts, registry modifications, and much more.

Based on the available data, the analyst's job is first to use their expertise to determine if the alert is a false positive or a true positive. In case of a true positive, the analyst can take actions from within the EDR console.

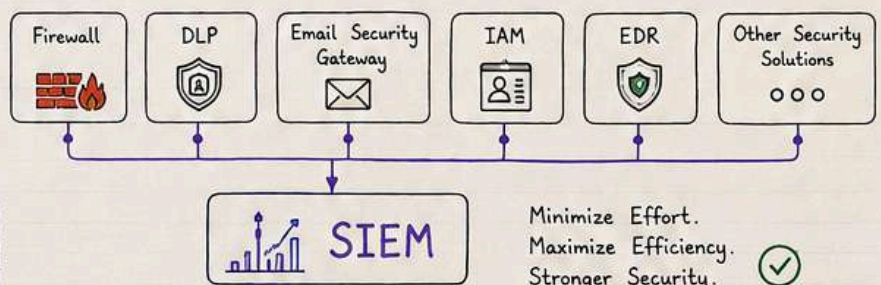
Analyst Actions from EDR Console

- Isolate Host
- Kill Process
- Quarantine File
- Delete File
- Rollback Registry Change
- Remote Shell / Live Response
- Collect Forensics (Memory, Files, Logs)

All with a few clicks! ✨

4 EDR WITH OTHER TOOLS

A standalone EDR provides strong protection for endpoints, but it works alongside other security solutions to form a larger security ecosystem.



EDR + Other Tools + SIEM = Powerful SOC Operations 😊

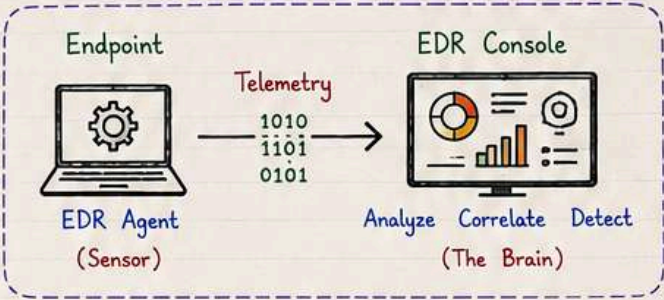
Task 5 : EDR Telemetry

★ What is Telemetry?

In the previous task, we learned about EDR agents, which collect different data from their endpoints and push it to the EDR console. This data is known as Telemetry. Telemetry is the black box of an endpoint with everything necessary for detection and investigation.



EDR
Collecting Data.
Powering Detection.
Enabling Investigation.



★ Collected Telemetry

Usually, many activities are going on in the endpoints, most of which are legitimate. It is often difficult to differentiate between regular and malicious activity. The more data is collected, the better judgments can be made. EDR collects detailed telemetry from the endpoints. Let's take a brief look at some of the telemetry that it collects:



Examples / What it helps detect

	1. Process Executions and Terminations	It keeps track of all the running and idle processes, which helps to identify suspicious child-parent process relationships, suspicious executables initiating a process, malware payload, etc.		Detects unusual parent-child relationships and malicious payload execution.
	2. Network Connections	All the endpoints' network connections are monitored, which helps identify any connection to a C2 server, unusual port usage, data exfiltration, or lateral movement within the network.		Detects connections to C2 servers, unusual ports and lateral movement.
	3. Command Line Activity	It captures all the commands executed on the endpoints in CMD, PowerShell, etc., which helps to identify malicious command execution, obfuscated PowerShell script executions, which are often missed by a traditional antivirus.		Detects malicious or obfuscated command execution.
	4. Files and Folders Modifications	Threat actors modify different files and folders during data staging, ransomware executions, and malicious file dropping. The EDR tracks this.		Detects malicious file creation, modification, deletion and data staging.
	5. Registry Modifications	The registry is a goldmine of information about the configurations in a Windows system. There are many registry modifications that occur during a malicious activity, and most of these are monitored by the EDR.		Detects suspicious registry changes that allow persistence, privilege escalation, or system tampering.

💡 EDR collects much more than this data from an endpoint. It uses complex logic and machine learning algorithms to assess the activities. Advanced threats keep most of their activities stealthy, using legitimate utilities during execution. Individually, their activities may seem harmless, but when observed through detailed telemetry, they tell a different story.



➔ This detailed telemetry not only helps the EDR detect advanced threats and make better judgments on the legitimacy of the activities, but it is also very helpful for the analysts during the investigations. The analysts can understand the full chain of events, identify the root cause, and reconstruct the attack timeline.



Task 6 : Detection And Response Capabilities

In this task, we will discuss the advanced detection techniques and the response mechanisms of an **EDR**.



EDR

- Detect Faster.
- Respond Smarter.
- Stop Threats.



Detection

Based on the telemetry received from the endpoints, some advanced detection techniques are applied to this data. Some of these techniques include:

(1) Behavioral Detection



Instead of just matching the signatures with known threats, it observes the complete behavior of a file. Advanced threats craft their malware to look clean and use legitimate processes to carry out their attack. **EDR** catches this behavior.

Example: A process **winword.exe** spawning **PowerShell.exe** will be flagged by the **EDR** due to the behavior. A Word document spawning a PowerShell is an unusual parent-child relationship.

(2) Anomaly Detection



With time, **EDR** understands the baseline behavior of the endpoints. Any activity that deviates from this behavior will be flagged. During any malicious activity, the endpoint's behavior deviates from normal. **EDR** picks it up.

Example: On one of the endpoints, a process modifies an **auto-start registry key**, which is not a common behavior on the endpoint.

(3) IOC Matching



EDRs have some strong threat intelligence field integrations. Except for zero-day attacks, most of the attacks have indicators published in the threat intelligence feeds. **EDR** flags any activity that matches any known **IOC**.

Example: A user downloads a file that drops an executable. The **hash** of this executable will get matched with the threat intelligence feed and instantly flagged by the **EDR**.

(4) MITRE ATT&CK Mapping



Any activity flagged by the **EDR** is not only marked as malicious or suspicious but also mapped with the **MITRE** Tactic and **Technique** (attack stage) that the particular activity was on.

Example: If the **EDR** flags the creation of a scheduled task for any reason, it will likely map this activity to the following:

- **Tactic:** Persistence
- **Technique:** Scheduled Task/Job

(5) Machine Learning Algorithms



Advanced threat actors try to evade defenses as much as possible, and their activities may sometimes bypass advanced detection techniques. Modern **EDRs** have machine learning models trained by a large dataset of normal and malicious behaviors. This can detect complex patterns of an attack.

Example: Attacks in which the individual actions are not inherently malicious, but the **ML** algorithm identifies the whole chain of activities as malicious. Fileless attacks and multi-staged intrusions are often detected through this.



Response

The next step after any detection is the response. **EDR** offers both automated and manual responses. You can make policies to block known malicious behaviors automatically. However, manual response gives you a wide range of response capabilities.



Isolate Host Contains the threat by disconnecting the endpoint from the network.



Terminate Process Stops malicious activity without isolating the host.



Quarantine Moves malicious file to an isolated location.

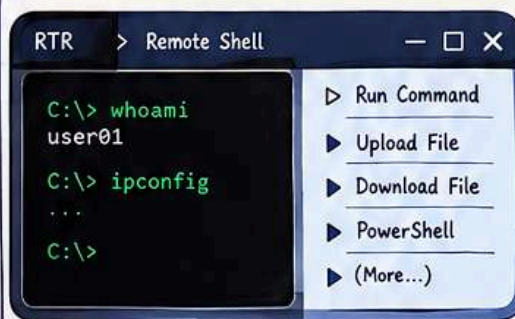


Remote Access Gives analysts shell access to the endpoint.



Artefacts Collection Extracts data for forensic investigation or reporting.

CrowdStrike Falcon EDR - RTR Console



Key Takeaway:

EDR uses advanced detection techniques and rich endpoint telemetry to identify sophisticated threats and provides powerful response options to stop and contain them.



EDR vs Traditional AV

Feature	Antivirus (AV)	EDR
Detection	Signature-based	Behavior + ML
Visibility	Limited	Deep (Telemetry)
Response	Basic	Active & Granular